

Mã học phần: NSE330380

Tên học phần: An toàn thông tin

Tên Tiếng Anh: Information Security

Số lượng tín chỉ: 03 tín chỉ

Đánh giá:

☐ **Quá trình: 50% (Thực hành Lab 30% + Kiểm tra online 20%)**

☐ **Cuối kỳ: 50%**

Chương 1: Tổng quan

Chương 2: Bảo mật phần mềm và Bảo mật HĐH

Chương 3: Xác thực và Kiểm soát truy cập

Chương 4: An toàn Cơ sở dữ liệu

Chương 5: Phần mềm độc hại

Chương 6: Firewalls & IDS/IPS

Chương 7: Tổng quan về Mã hoá

Chương 8: Mã hoá đối xứng

Chương 9: Mã hóa bất đối xứng/ khóa công khai

AN TOÀN THÔNG TIN (INSE330380)

CHƯƠNG I TỔNG QUAN AN TOÀN THÔNG TIN

Ths. ĐỖ MINH HẬU

- ❑ Giới thiệu an toàn thông tin: sự cần thiết, khái niệm, lịch sử, đặc điểm
- ❑ Các thành phần cơ bản, tiêu chuẩn ATTT
- ❑ Các thuật ngữ của an toàn thông tin, bảo mật máy tính
- ❑ Các mối nguy hiểm của ATTT: đe dọa, lỗ hổng, tấn công
 - Tấn công surface và tree
- ❑ Nguyên tắc thiết kế bảo mật cơ bản
- ❑ Chiến lược bảo mật máy tính.

- ❑ Thông tin là một tài sản, giống như các tài sản kinh doanh quan trọng khác, có giá trị đối với một tổ chức và do đó cần được bảo vệ phù hợp.
- ❑ Những gì có giá trị hay riêng tư thường bị nhòm ngó và có nguy cơ bị tổn hại.
 - Thông tin cá nhân
 - Thông tin doanh nghiệp, chính phủ....
- ❑ Các thông tin đều được lưu trữ trên Internet – nguy cơ mất an toàn rất cao
 - Những kẻ bất chính có thể kiếm lợi bằng cách kiểm soát nó
 - Hậu quả sự truy cập trái phép, làm mất an toàn thông tin có thể gây thảm họa về kinh tế, chính trị, con người
- ❑ Chúng ta cần hiểu được rủi ro đối với thông tin và hệ thống trực tuyến của mình
- ❑ Chúng ta cần phát triển tư duy bảo mật

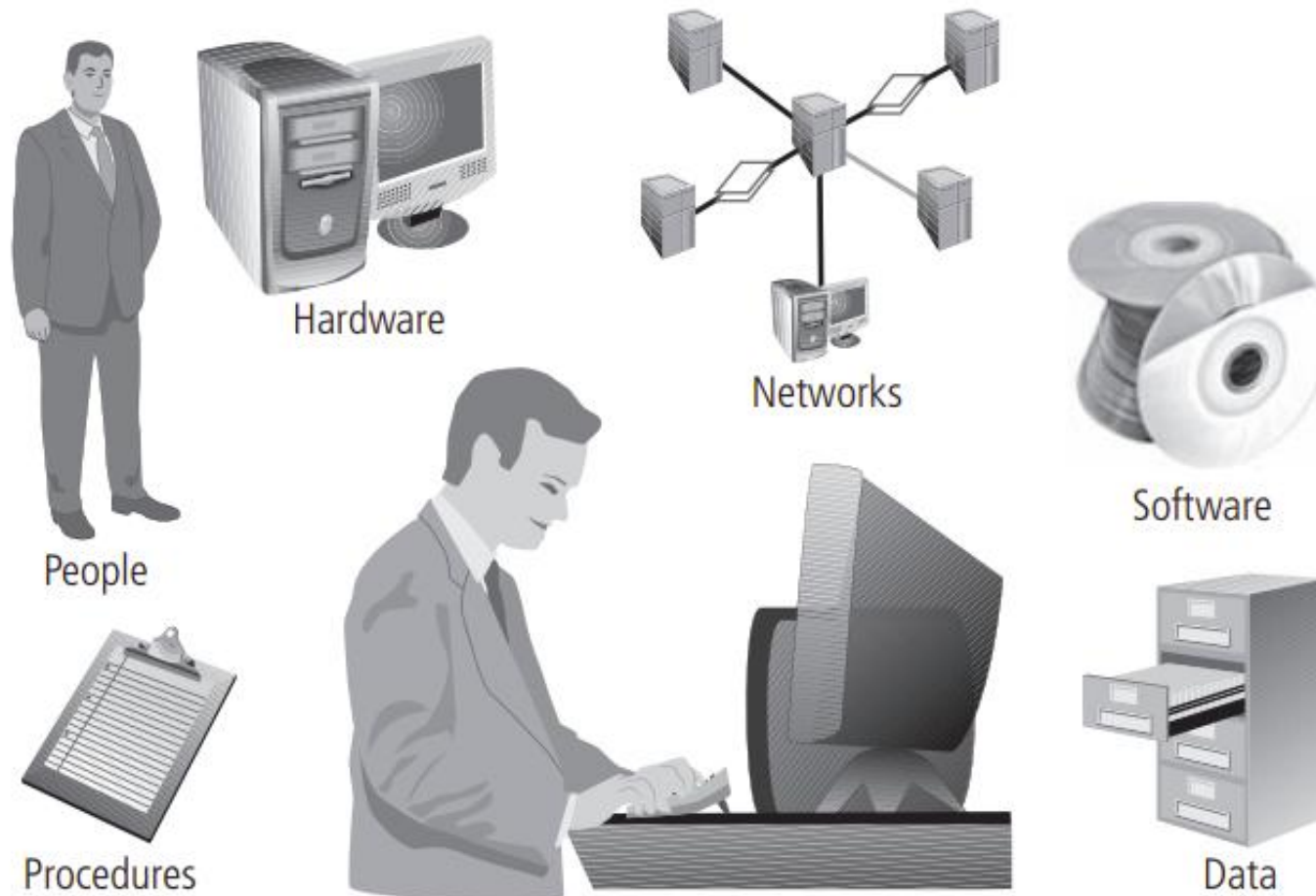
Bảo mật thông tin có giá trị vì nó:

- ☐ **Bảo vệ thông tin khỏi nhiều mối đe dọa khác nhau**
- ☐ **Đảm bảo tính liên tục của hoạt động kinh doanh và bảo mật thông tin trong các sự cố**
- ☐ **Giảm thiểu tổn thất tài chính và các tác động khác**
- ☐ **Tối ưu hóa lợi tức đầu tư**
- ☐ **Tạo cơ hội để kinh doanh an toàn**
- ☐ **Duy trì quyền riêng tư và tuân thủ**

Định nghĩa về bảo mật thông tin đã được đưa ra bởi nhiều nguồn khác nhau

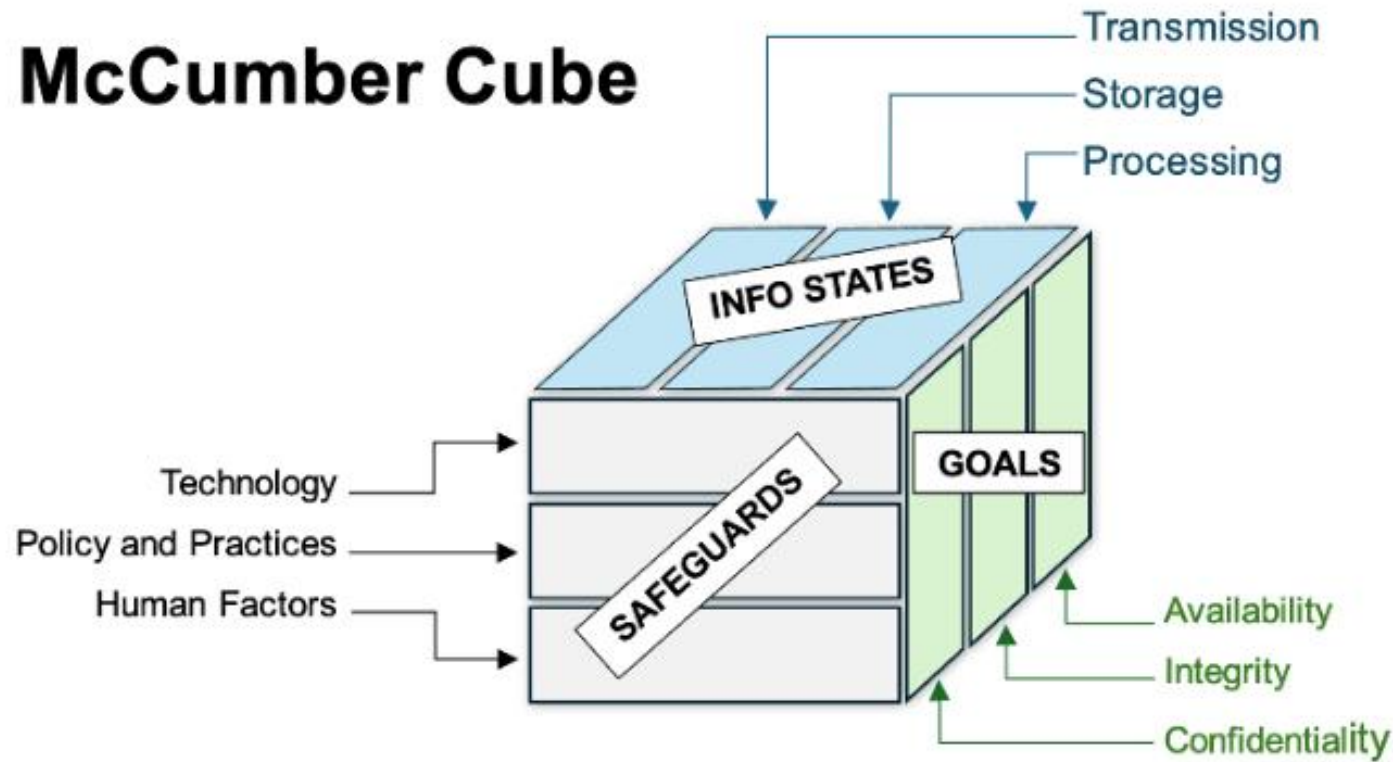
- ❑ Là sự đảm bảo về tính bảo mật, tính toàn vẹn và tính khả dụng của thông tin. Bổ sung: Các đặc điểm khác như tính xác thực, tính tự chịu trách nhiệm, tính không thể chối cãi và độ tin cậy cũng có thể liên quan (ISO/IEC 27000:2009).
- ❑ Là một “sự đảm bảo được thông báo đầy đủ về các rủi ro và kiểm soát thông tin được cân bằng.” —James Anderson, Inovant (2002)

- ☐ Bắt đầu ngay sau khi các máy tính lớn đầu tiên được phát triển
- ☐ Các nhóm phát triển các tính toán mã hoá trong Chiến tranh Thế giới II đã tạo ra các máy tính hiện đại đầu tiên
- ☐ Kiểm soát vật lý để hạn chế truy cập vào các địa điểm quân sự nhạy cảm cho nhân viên được ủy quyền

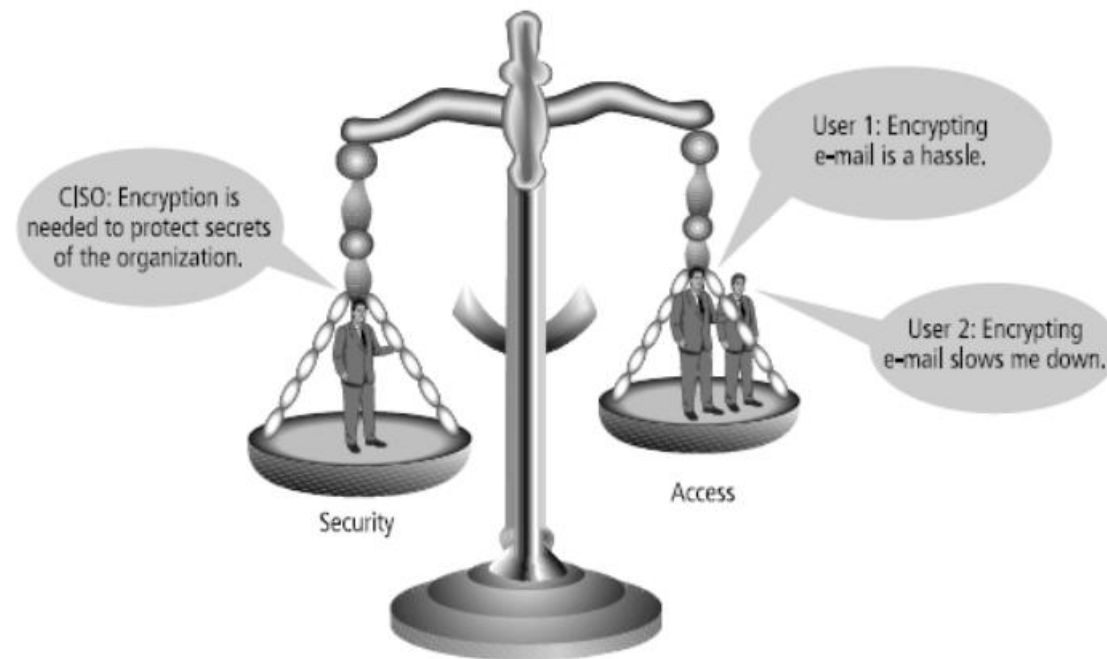


Thuộc tính	Ý nghĩa	Ví dụ
Khả dụng (Availability)	Người được phép truy cập khi cần , dịch vụ không bị “sập”	DoS làm web chết
Bảo mật (Confidentiality)	Không lộ cho người không được phép	Rò rỉ dữ liệu KH
Toàn vẹn (Integrity)	Không bị sửa/đổi trái phép; dữ liệu còn nguyên	So sánh hash, chống sửa log
Xác thực (Authenticity)	Đúng nguồn/đúng tác giả , không bị giả mạo	Email chống spoofing, chữ ký số
Độ chính xác (Accuracy)	Giá trị dữ liệu đúng thực tế , ít sai số	Số dư đúng với giao dịch thực
Tiện ích/Hữu ích (Utility)	Dữ liệu dùng được cho mục đích (đúng dạng/đúng khóa giải mã/đúng ngữ cảnh)	Có file nhưng bị mã hóa nên vô dụng
Sở hữu/Kiểm soát (Possession/Control)	Ai đang nắm quyền kiểm soát dữ liệu/hệ thống (kể cả khi chưa đọc được)	Mất laptop chứa dữ liệu mã hóa

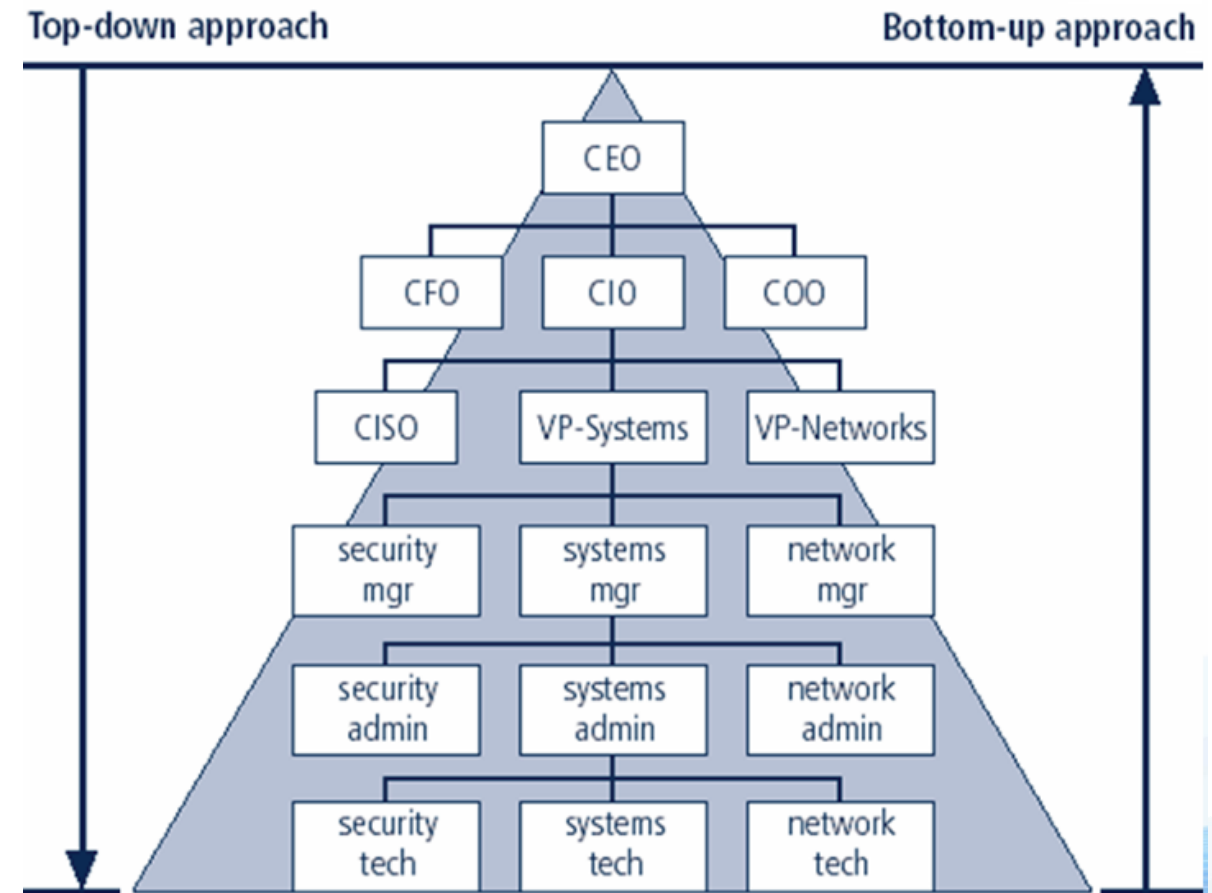
- ❑ Ủy ban Hệ mống An ninh Quốc gia (Hoa Kỳ) đưa ra Mô hình An ninh Thông tin và đang trở thành Tiêu chuẩn Đánh giá
 - 27 Ô đại diện cho các lĩnh vực phải được giải quyết trong quy trình bảo mật



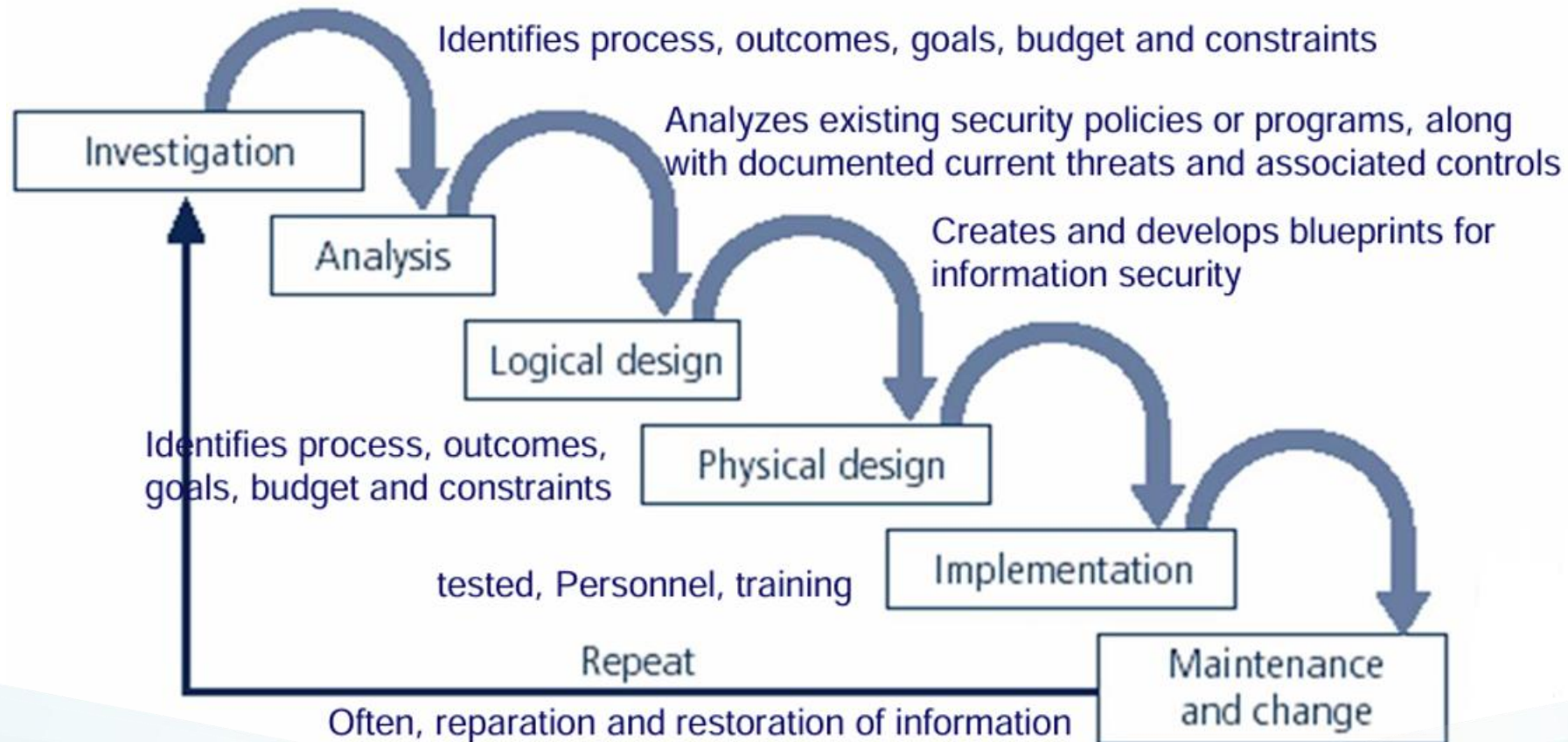
- ❑ Để đạt được sự cân bằng, mức độ bảo mật phải cho phép truy cập hợp lý, nhưng vẫn bảo vệ chống lại các mối đe dọa
- ❑ Khi xem xét bảo mật thông tin, điều quan trọng là phải nhận ra rằng không thể có được an ninh hoàn hảo.



- ❑ Cách giải quyết vấn đề bằng một chuỗi các thủ tục có cấu trúc
- ❑ Hướng của các mũi tên lên hay xuống để chỉ ra nguồn gốc của kế hoạch và áp lực thành công được thúc đẩy từ hướng nào.



- ❑ Chu trình được điều chỉnh để hỗ trợ việc triển khai chuyên biệt của một dự án an toàn thông tin.
- ❑ Xác định các mối đe dọa cụ thể và tạo ra các biện pháp kiểm soát để chống lại chúng.



- ❑ Các tổ chức cần thiết phải bảo mật thông tin, thực hiện bốn chức năng quan trọng
 - Bảo vệ khả năng hoạt động của tổ chức
 - Cho phép vận hành an toàn các ứng dụng đang chạy trên hệ thống CNTT của tổ chức
 - Bảo vệ dữ liệu mà tổ chức thu thập và sử dụng
 - Bảo vệ tài sản công nghệ của tổ chức
- ❑ Cơ cấu tổ chức được yêu cầu triển khai các chi tiết của chương trình ATTT
 - Ban quản lý cấp cao (yếu tố quyết định: định hướng, ngân sách, chấp thuận rủi ro)
 - Hỗ trợ hành chính (quy trình, nhân sự, mua sắm, tuân thủ, truyền thông nội bộ)
 - Chuyên môn kỹ thuật (thiết kế/triển khai kiểm soát: IAM, logging, backup, hardening,...)

- ❑ **CIO (Chief Information Officer):** Tập trung vào chiến lược CNTT, ngân sách, vận hành hệ thống, dự án IT, và tư vấn cho lãnh đạo về định hướng công nghệ.
- ❑ **CISO (Chief Information Security Officer):** Chủ yếu chịu trách nhiệm đánh giá, quản lý và thực hiện an toàn thông tin trong tổ chức; thông thường báo cáo trực tiếp cho CEO.

Nhóm dự án an ninh thông tin:

☐ Quyết định & tài trợ (Champion)

- Champion: thúc đẩy, hỗ trợ tài chính và hành chính

☐ Quản trị & điều phối (PM + policy/risk)

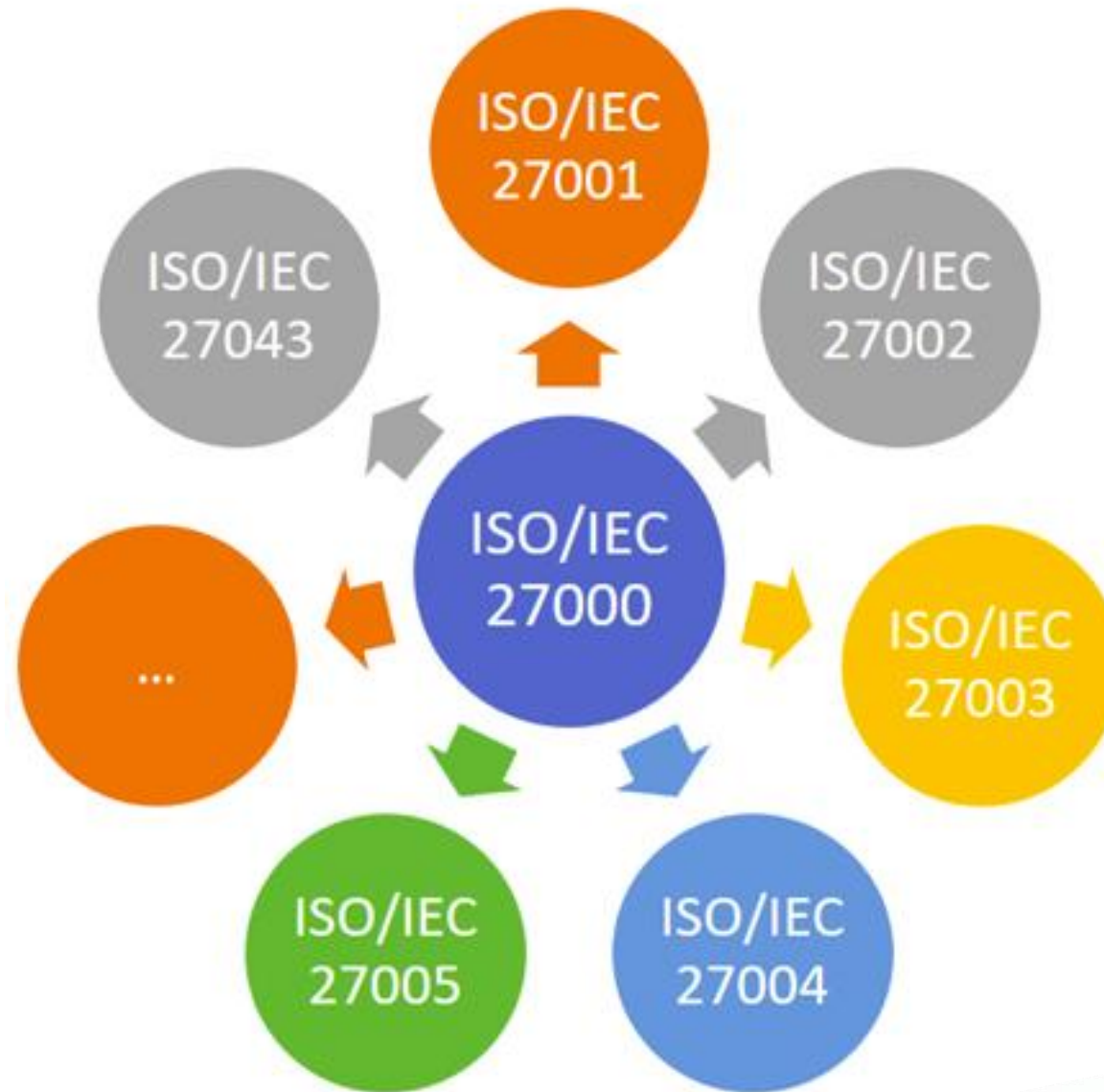
- Trưởng nhóm: hiểu về quản lý dự án
- Các nhà phát triển chính sách bảo mật: hiểu được văn hoá, chính sách công ty

☐ Triển khai & vận hành (security + admins + users)

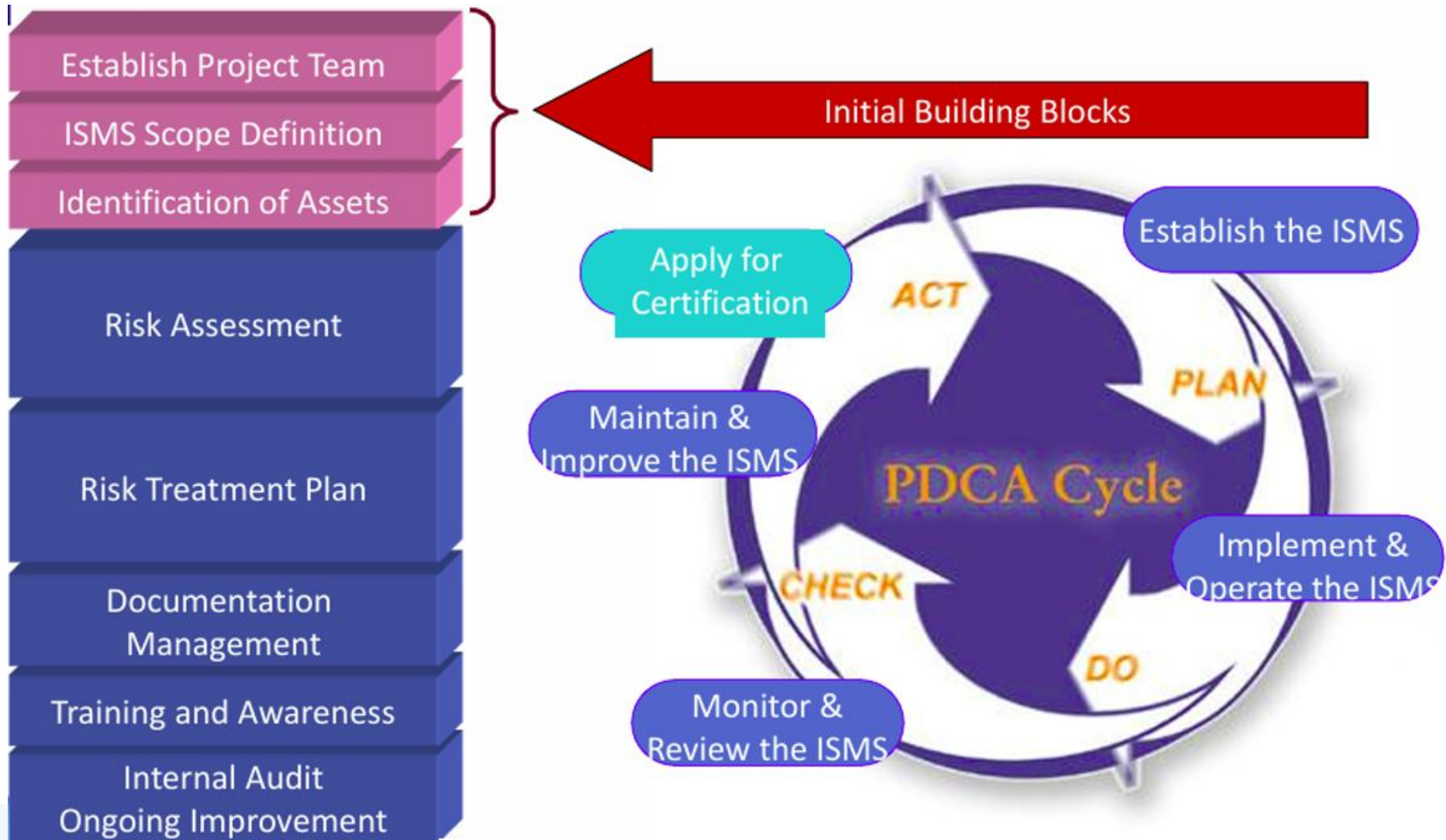
- Chuyên gia đánh giá rủi ro: kỹ thuật đánh giá rủi ro tài chính, phương pháp bảo mật
- Chuyên gia bảo mật: các chuyên gia được đào tạo và có giáo dục tốt
- Quản trị hệ thống: trách nhiệm chính trong việc quản lý, vận hành hệ thống
- Người dùng cuối

ISO/IEC 27000 Family - Tiêu chuẩn bảo mật thông tin được Tổ chức Tiêu chuẩn hóa Quốc tế (ISO) và Ủy ban Kỹ thuật Điện quốc tế (IEC) công bố chung. Bao gồm các tiêu chuẩn như:

- ❑ TCVN ISO/IEC 27001:2009 CNTT - Hệ thống quản lý ATTT – Các yêu cầu (Information technology - Information security management system - Requirements)
- ❑ TCVN ISO/IEC 27002:2011 CNTT - Các kỹ thuật an toàn- Quy tắc thực hành Quản lý ATTT (Information technology - Security techniques Code of practice for information security management)



Triển khai



☐ Bộ tiêu chuẩn về đánh giá an toàn:

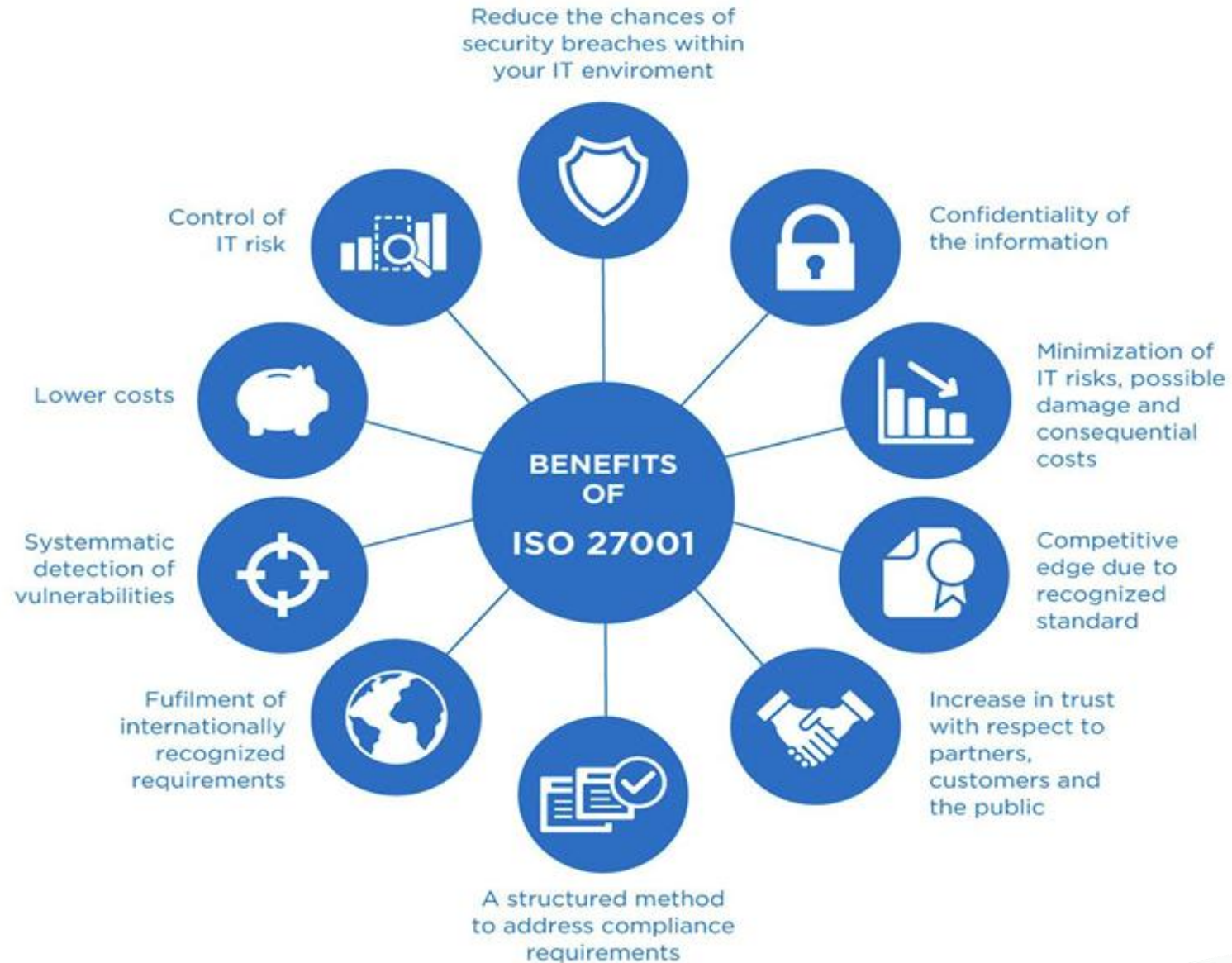
- ISO/IEC 15408-1:2009 CNTT - Các kỹ thuật an toàn- Các tiêu chí đánh giá an toàn CNTT- Phần 1,2,3

☐ Bộ tiêu chuẩn về an toàn mạng:

- ISO/IEC 27033 gồm 6 phần

☐ Bộ tiêu chuẩn về quản lý sự cố ATTT:

- ISO/IEC 27035

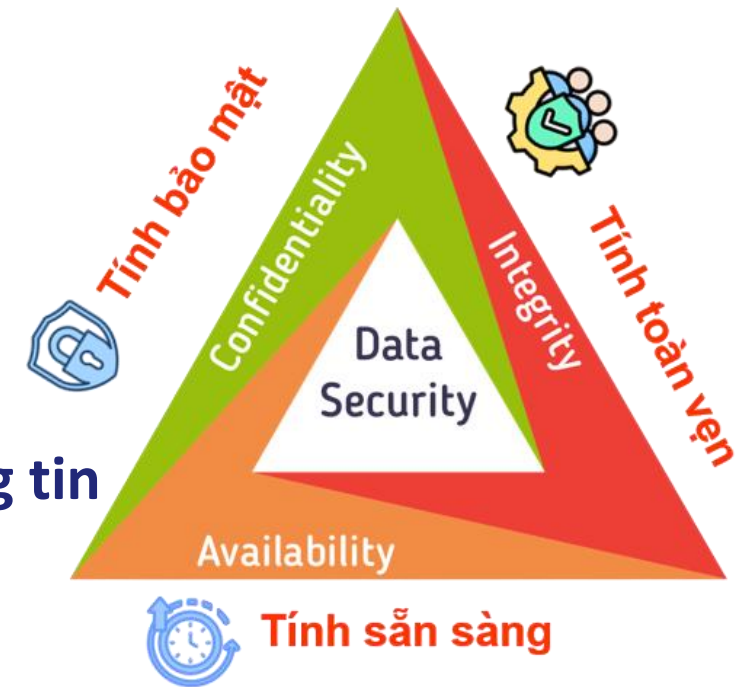


Luật An toàn thông tin mạng 2015 bao gồm 54 Điều luật và 08 Chương cụ thể:

- ☐ Chương 1: Những quy định chung
- ☐ Chương 2: Bảo đảm an toàn thông tin mạng
- ☐ Chương 3: Mật mã dân sự
- ☐ Chương 4: Tiêu chuẩn, quy chuẩn kỹ thuật an toàn thông tin mạng
- ☐ Chương 5: Kinh doanh trong lĩnh vực an toàn thông tin mạng
- ☐ Chương 6: Phát triển nguồn nhân lực an toàn thông tin mạng
- ☐ Chương 7: Quản lý nhà nước về an toàn thông tin mạng
- ☐ Chương 8: Điều khoản thi hành

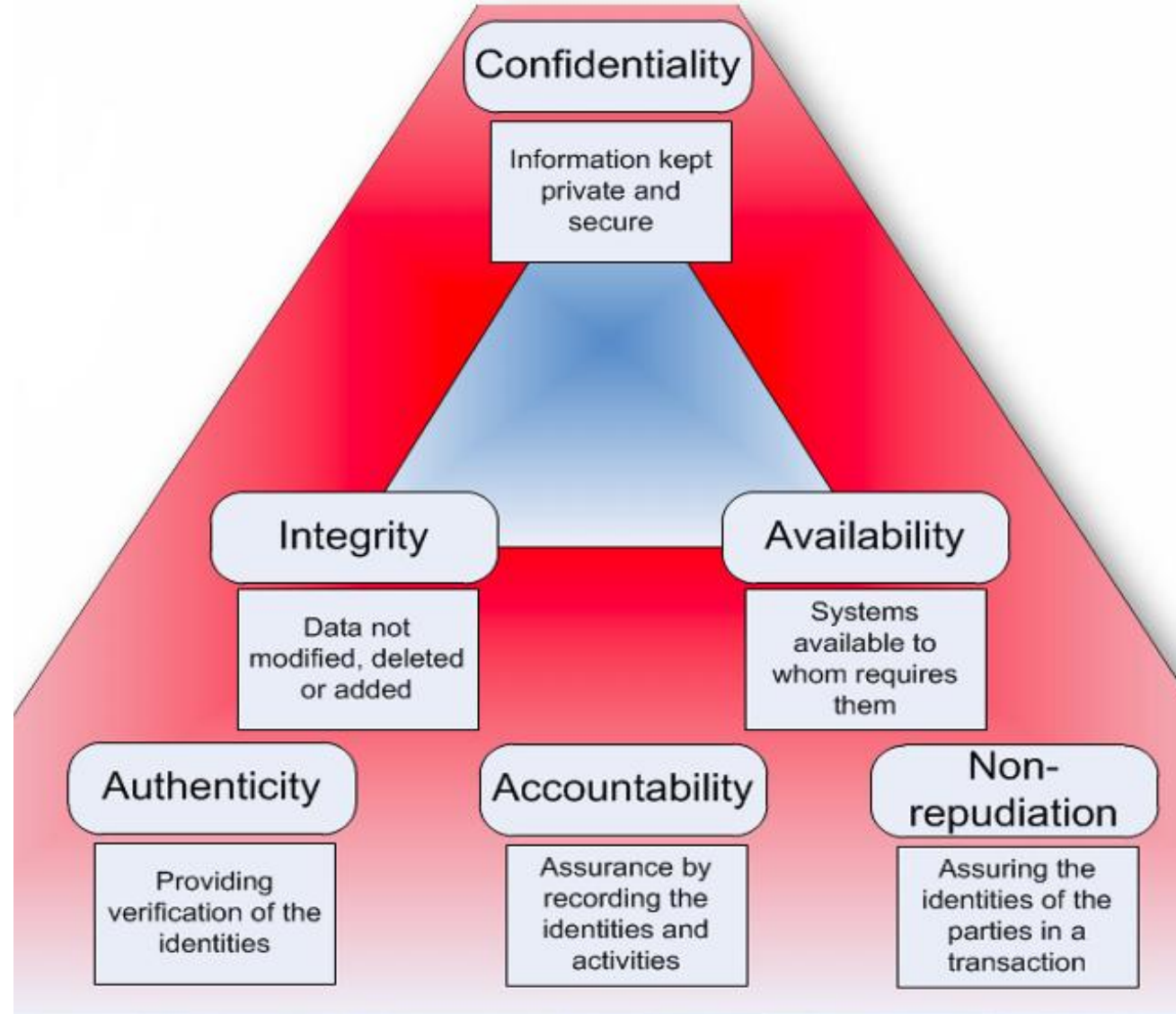
Bảo vệ hệ thống thông tin nhằm đạt được các mục tiêu áp dụng của việc bảo vệ tài nguyên hệ thống thông tin: (CIA Triad)

- ☐ Tính toàn vẹn: Ngăn chặn việc sửa đổi trái phép
- ☐ Tính sẵn sàng: Ngăn chặn việc gián đoạn dịch vụ và năng suất.
- ☐ Tính bí mật: Ngăn chặn việc tiết lộ trái phép hệ thống và thông tin (HTTT: bao gồm phần cứng, phần mềm, phần mềm cơ sở, thông tin/dữ liệu, và viễn thông)



CIA++

- ☐ Tính xác thực
- ☐ Tính chịu trách nhiệm
- ☐ Tính chống thoái thác



- ❑ **Attack** - tấn công: một hành vi cố ý hoặc không cố ý gây ra thiệt hại hoặc xâm phạm đến thông tin và / hoặc các hệ thống hỗ trợ nó.
- ❑ **Threats** - Các mối đe dọa: một loại đối tượng, người hoặc các thực thể khác đại diện cho mối nguy tiềm ẩn đối với tài sản.
- ❑ **Threat Agent** - một trường hợp cụ thể hoặc một thành phần của một mối đe dọa tổng quát hơn
- ❑ **Vulnerability**– lỗ hổng: điểm yếu hay lỗi của hệ thống hoặc cơ chế bảo vệ để lộ thông tin để tấn công hoặc hư hỏng

- ☐ Hacking: Hoạt động tìm hiểu/kiểm thử hệ thống; hợp pháp khi được cho phép, bất hợp pháp khi truy cập trái phép.
- ☐ Risk (rủi ro): Nguy cơ tổn thất khi mối đe dọa khai thác lỗ hổng, gây tác động (thường xét khả năng xảy ra $\times$ mức độ tác động).
- ☐ Asset (tài sản): tài nguyên tổ chức đang được bảo vệ. Bất kỳ thứ gì có giá trị và cần bảo vệ
- ☐ Control, Safeguard or Countermeasure: Biện pháp kỹ thuật/quy trình giúp giảm rủi ro
- ☐ Exploit: Cách/kỹ thuật dùng để khai thác lỗ hổng

- ☐ **Exposure:** Mức độ tài sản “phơi lộ” trước mối đe dọa do lỗ hổng/điểm yếu; biểu thị thiệt hại tiềm tàng.
- ☐ **Security Blueprint:** Bản thiết kế/kiến trúc & lộ trình triển khai các biện pháp bảo mật trong tổ chức.
- ☐ **Security Model:** Tập quy tắc/mô hình hoá để thực thi chính sách bảo mật.
- ☐ **Security Profile:** Tổng hợp hiện trạng bảo mật đang áp dụng (policy, quy trình, cấu hình, công nghệ, đào tạo).

Threats

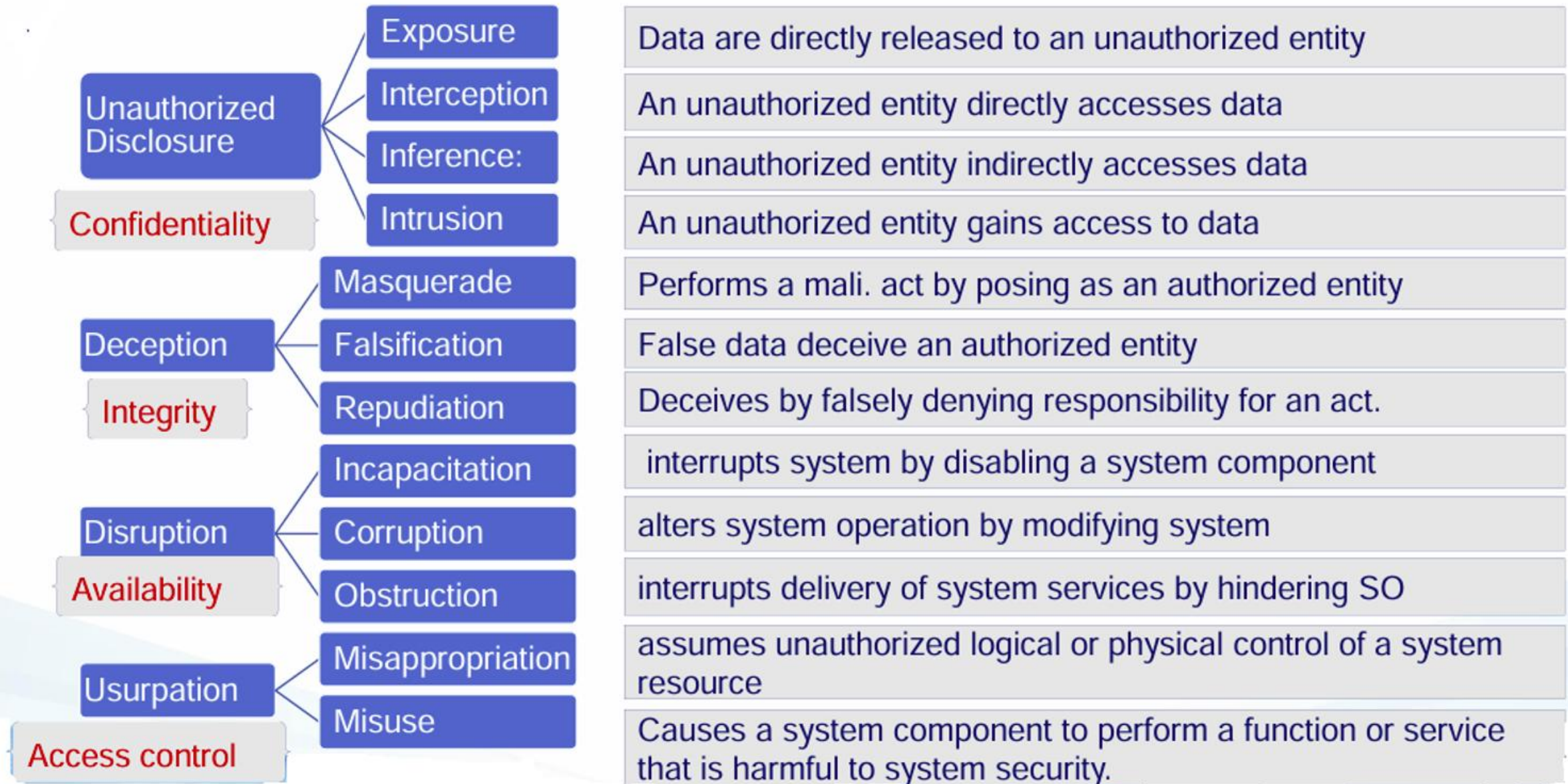


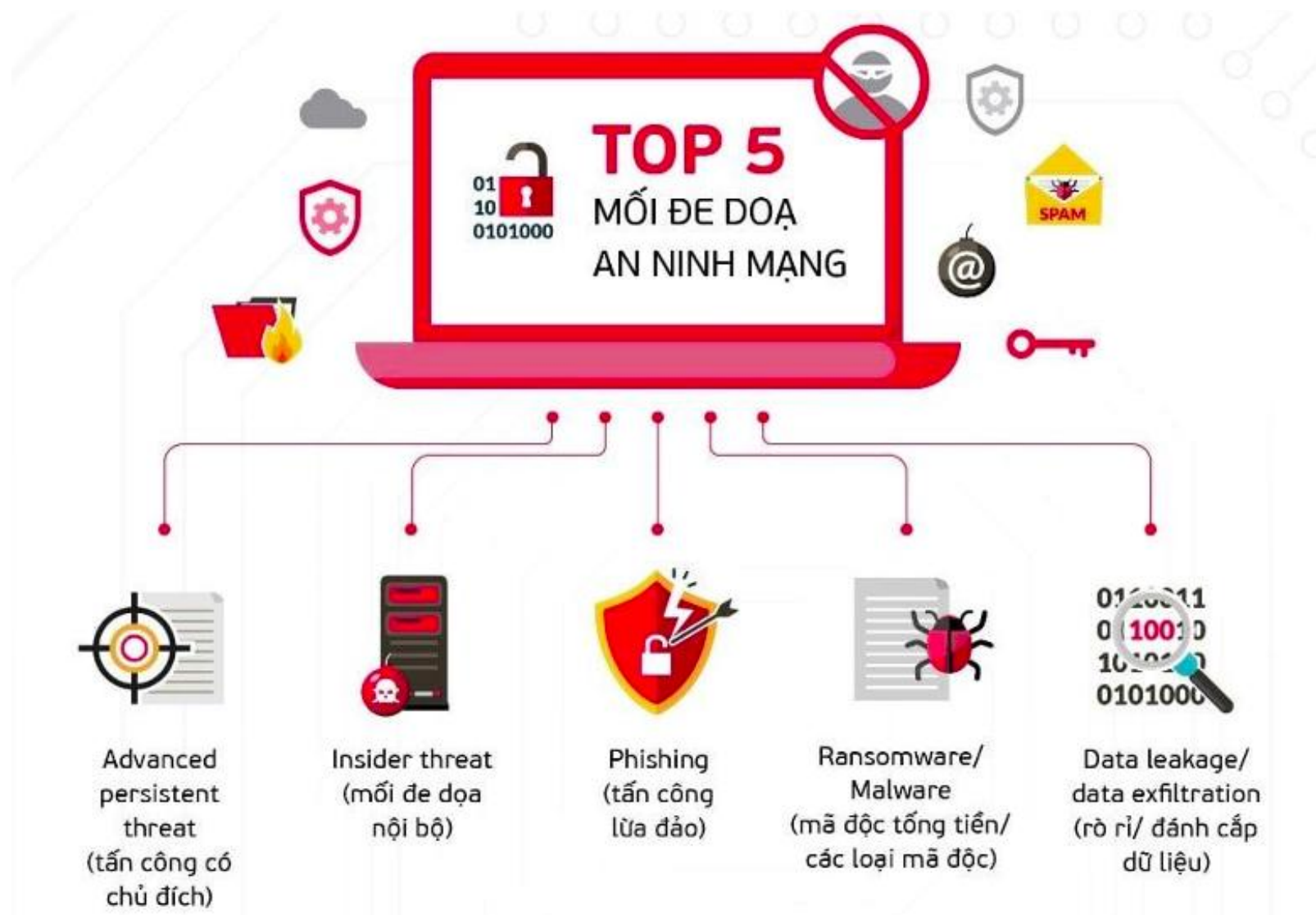
Vulnerabilities



Attacks







❑ Lỗ hổng bảo mật- Security vulnerability: một lỗ hổng hoặc điểm yếu

- Có thể là lỗi thiết kế hoặc lỗi triển khai, cho phép kẻ tấn công gây hại cho các bên liên quan của ứng dụng
- Một lỗ hổng với ít nhất một vec-tơ tấn công thì loại lỗ hổng có thể bị khai thác.
- Cửa sổ của lỗ hổng (window) là thời gian từ khi lỗ hổng được xác định đến khi được vá.

❑ Nguồn gốc lỗ hổng:

- Phòng thủ yếu
- Quản lý tài nguyên rủi ro
- Tương tác không an toàn giữa các thành phần

Các loại lỗi hỏng phổ biến



**Vulnerabilities
in the source
code**



**Misconfigured
system
components**



**Trust
configurations**



**Weak
credentialing
practices**



**Lack of
strong
encryption**



**Insider
threat**



**Psychological
vulnerability**



**Inadequate
authentication**



**Injection
flaws**



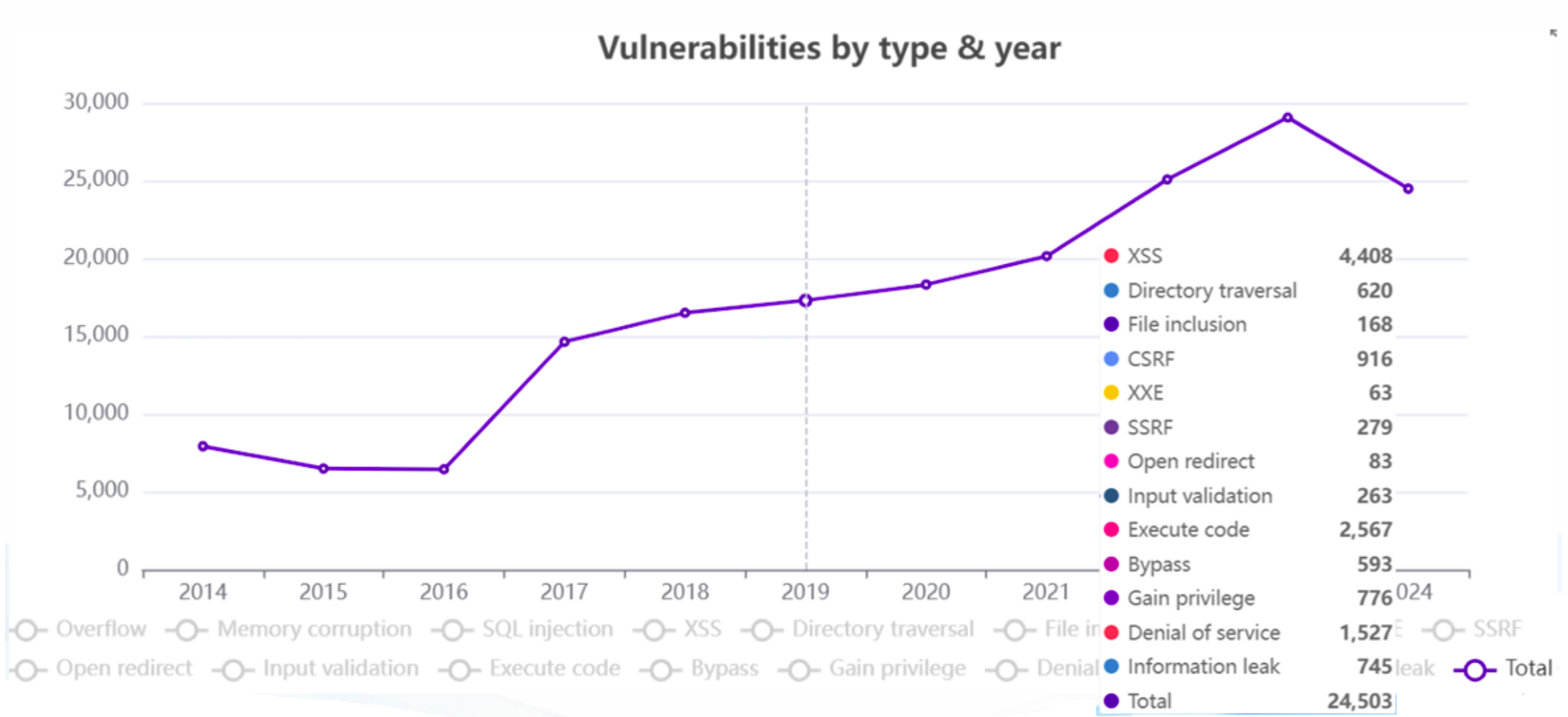
**Sensitive
data exposure**



**Insufficient
monitoring
and logs**



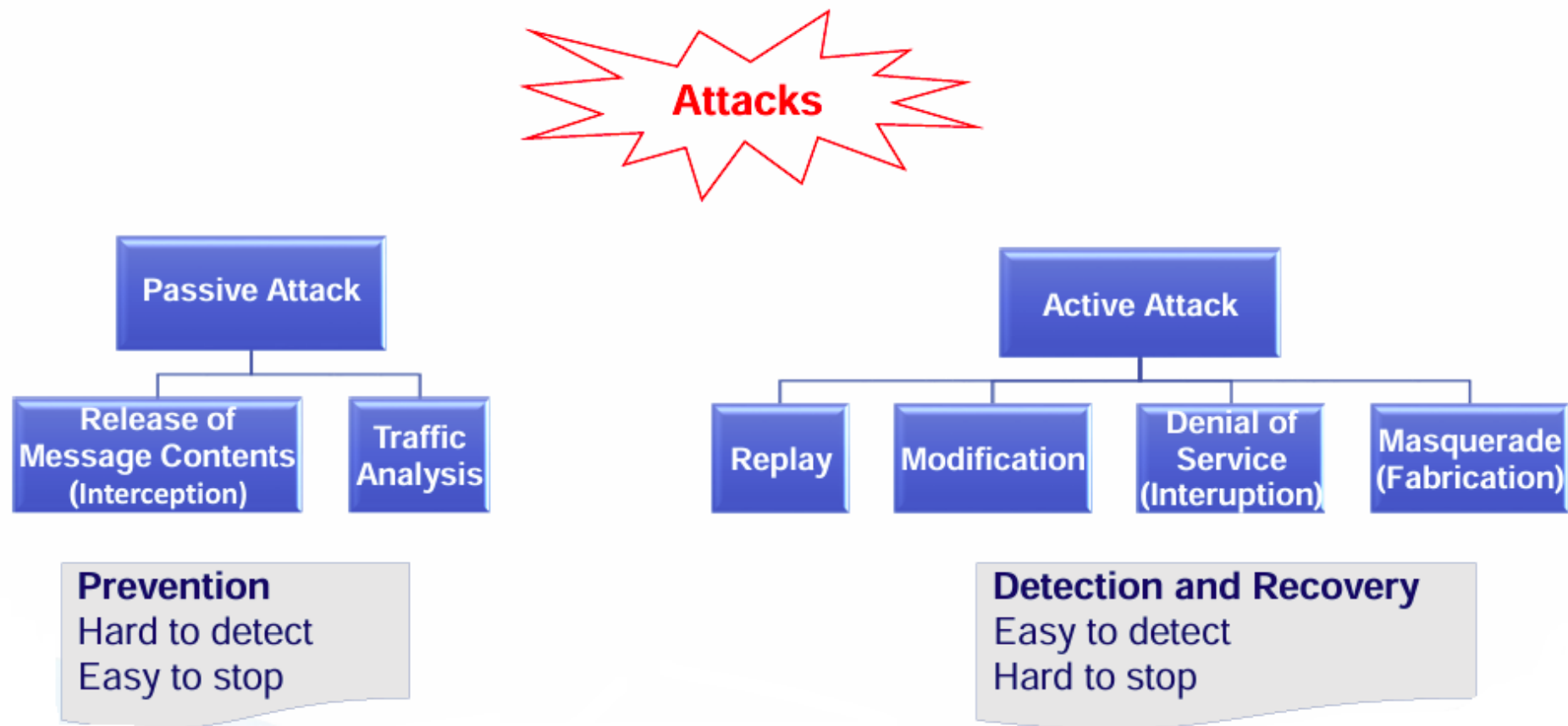
**Shared
tenancy
vulnerabilities**



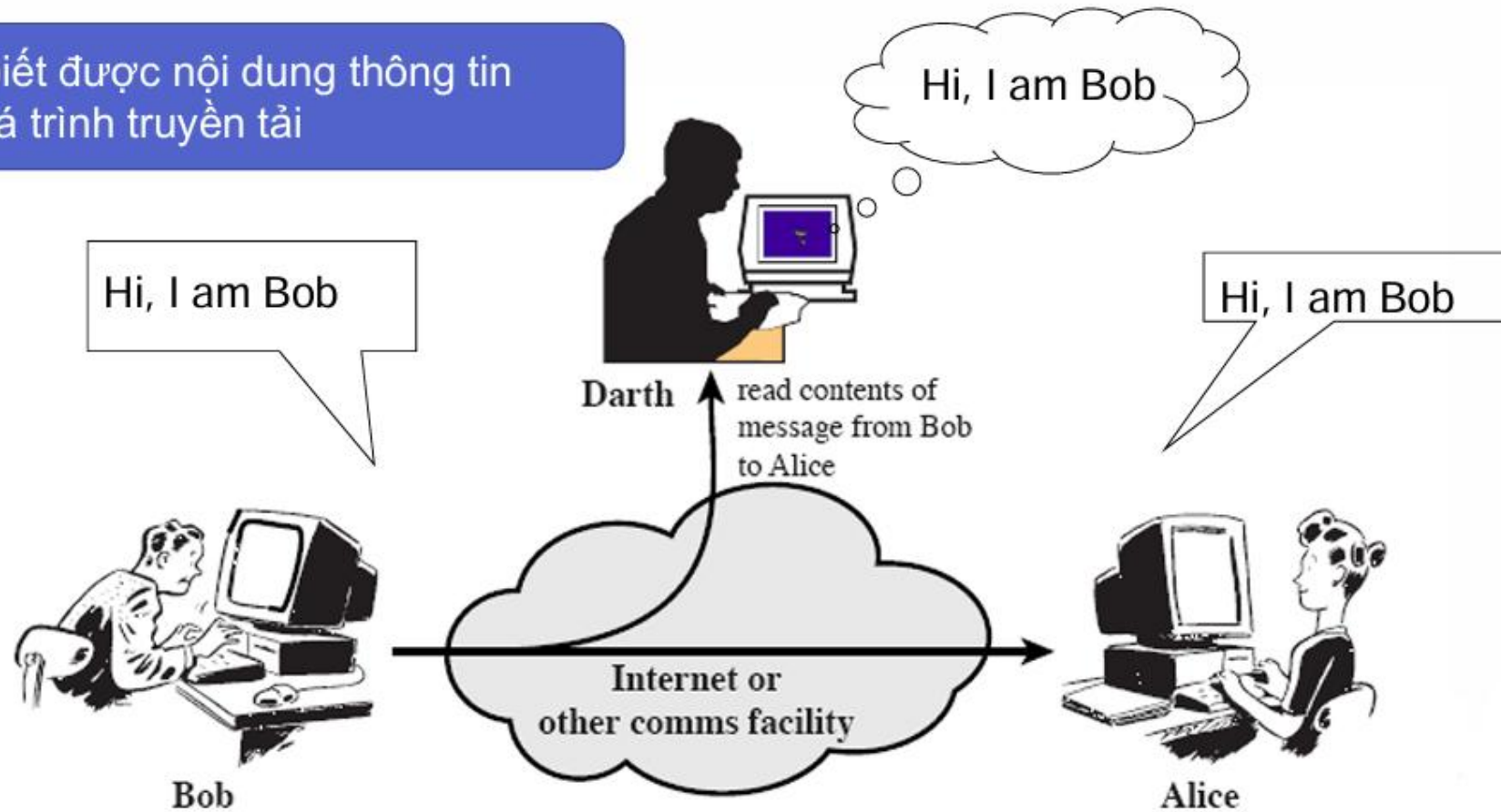
Quản lý lỗ hổng là một quy trình an ninh mạng liên tục bao gồm xác định, đánh giá, xử lý và báo cáo các lỗ hổng mạng và phần mềm.

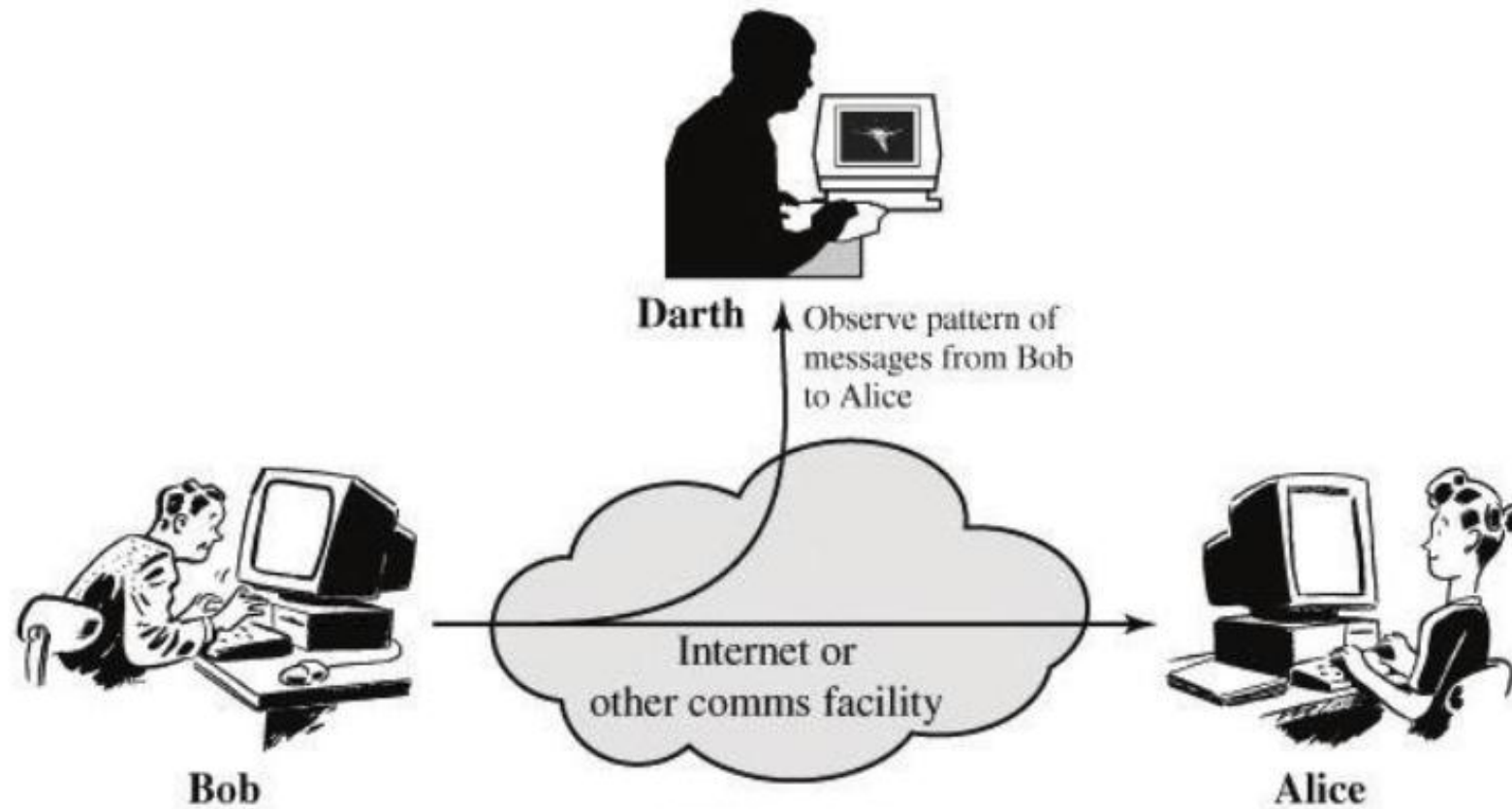


Các kiểu tấn công mạng



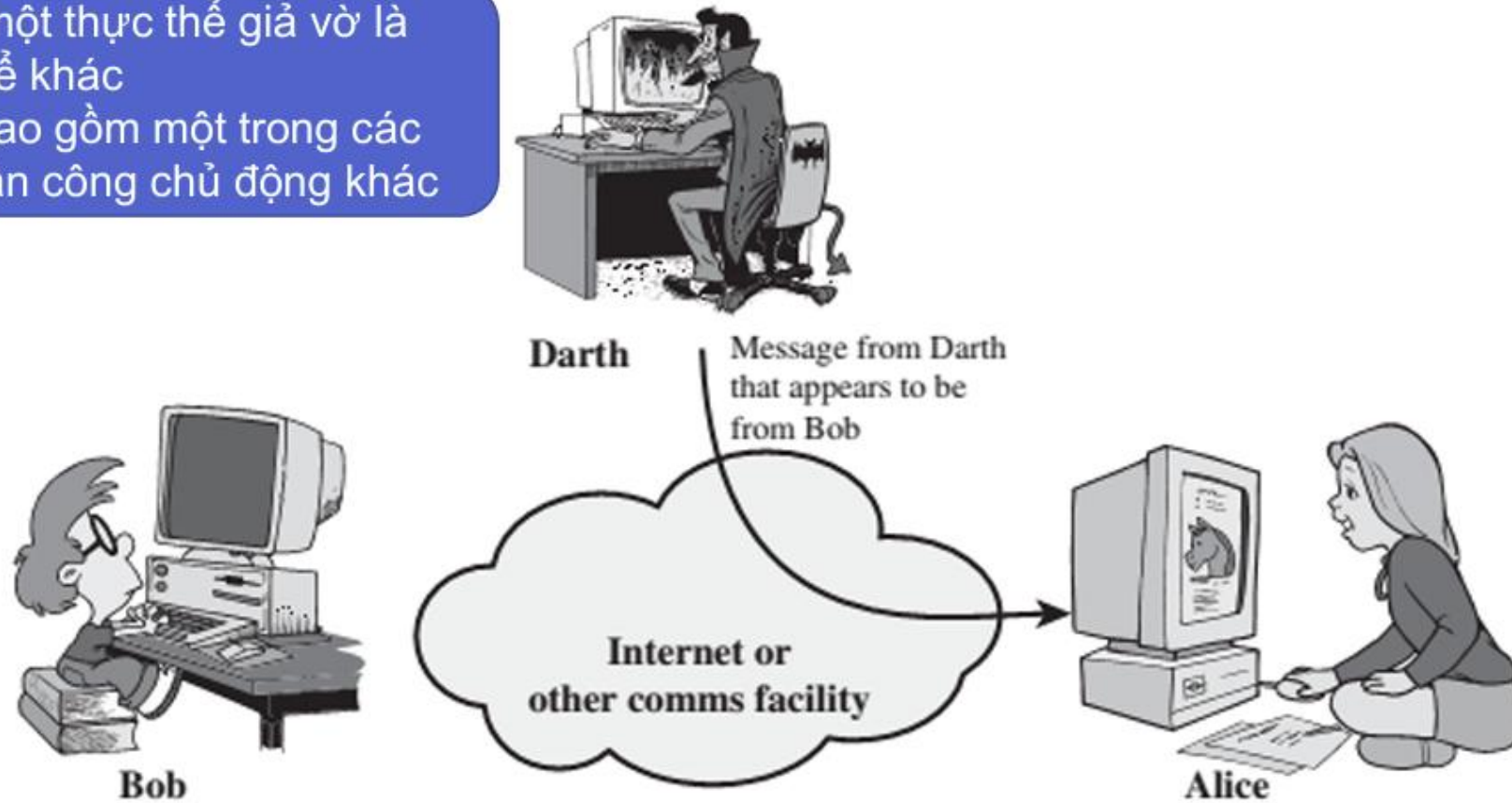
đối thủ biết được nội dung thông tin trong quá trình truyền tải



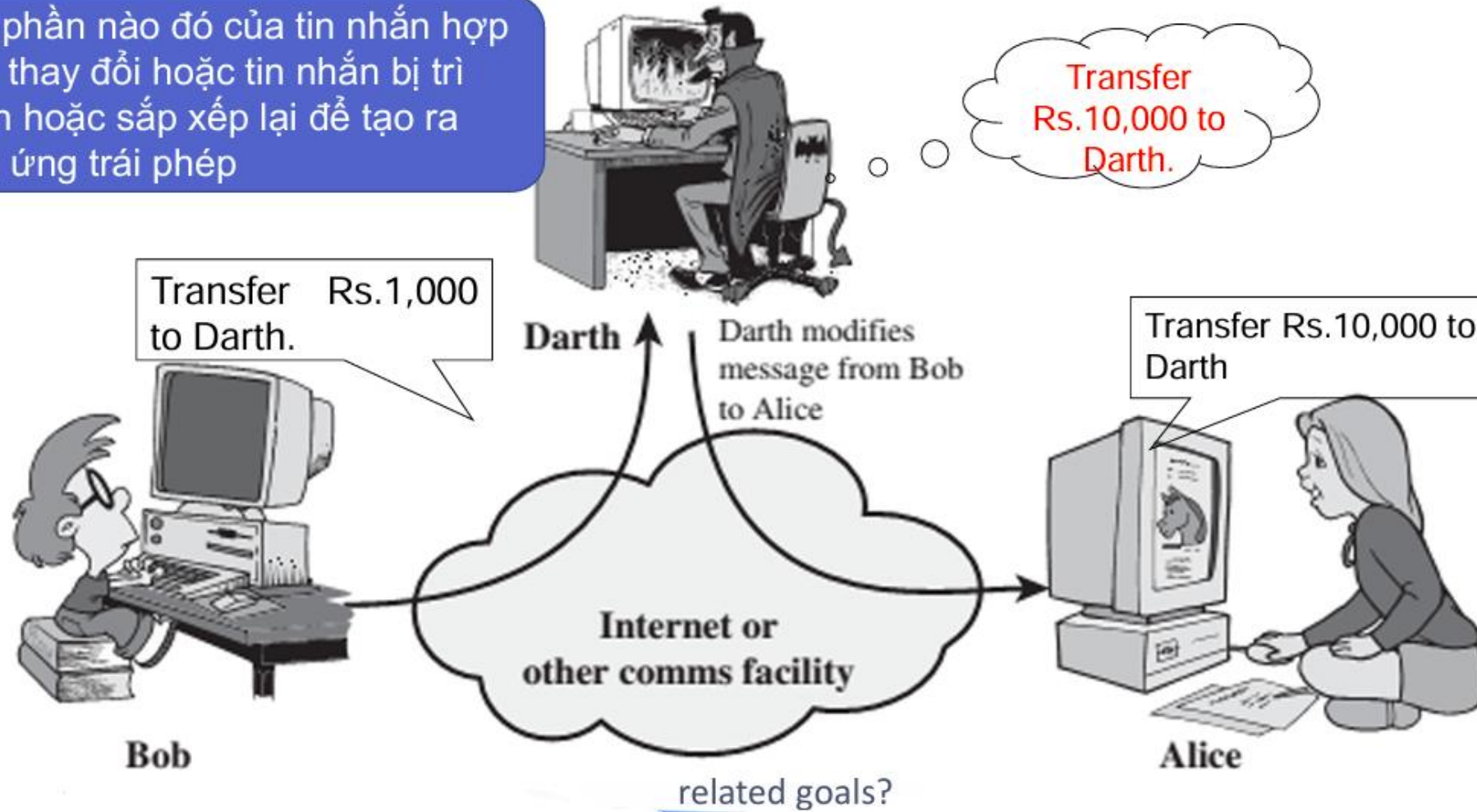


Xảy ra khi một thực thể giả vờ là một thực thể khác

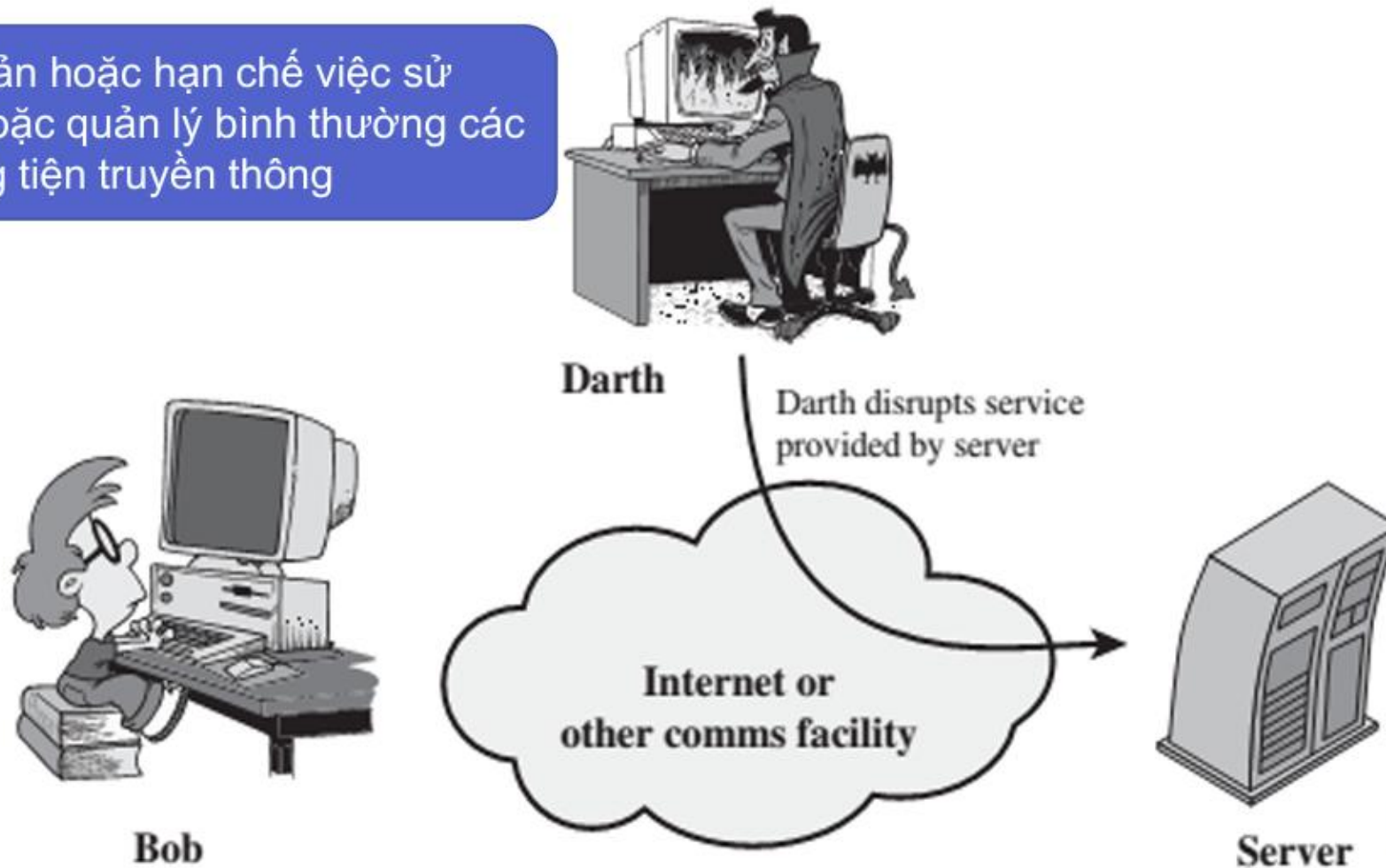
- Thường bao gồm một trong các hình thức tấn công chủ động khác

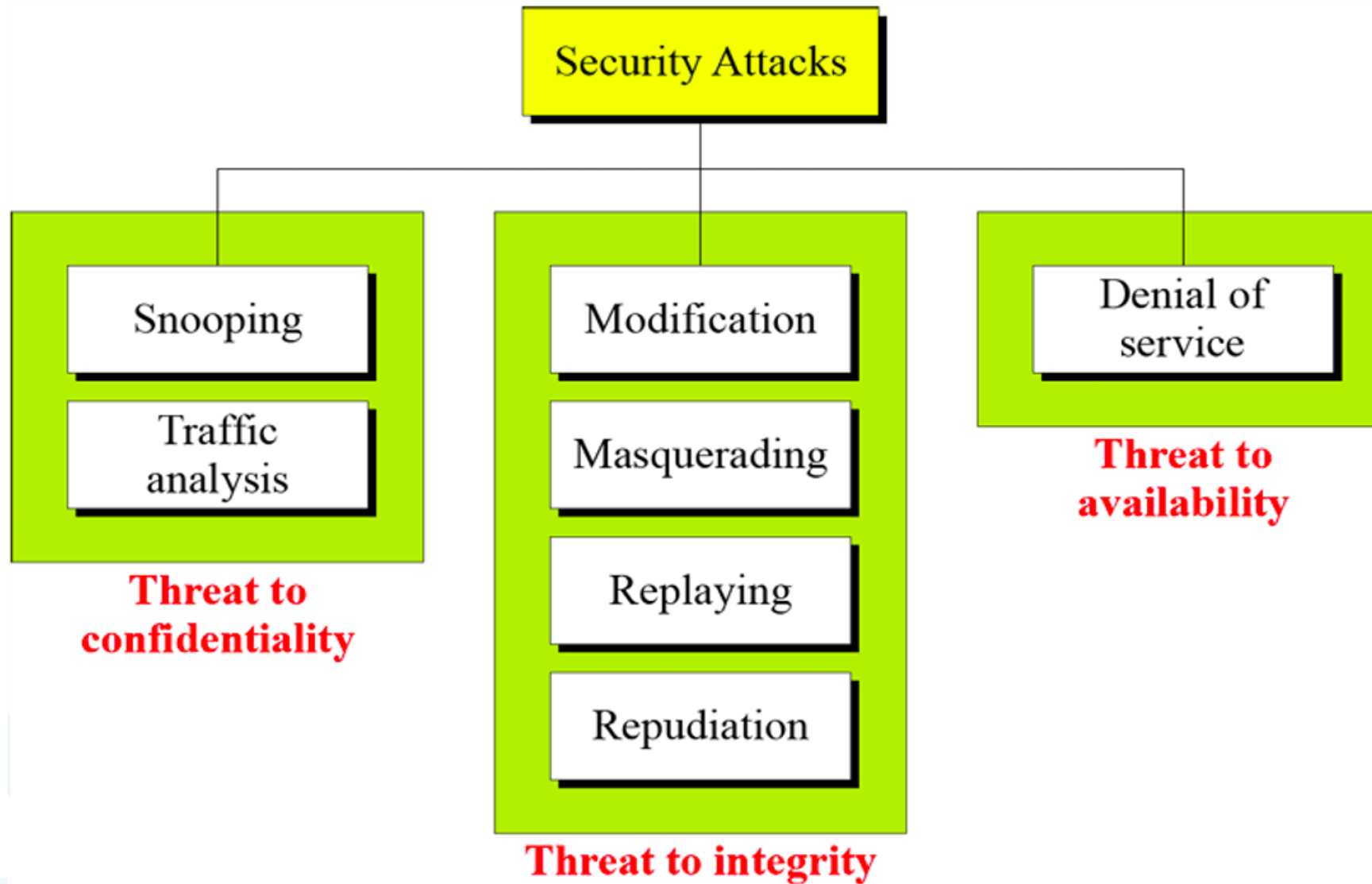


Một phần nào đó của tin nhắn hợp lệ bị thay đổi hoặc tin nhắn bị trì hoãn hoặc sắp xếp lại để tạo ra hiệu ứng trái phép



Ngăn cản hoặc hạn chế việc sử dụng hoặc quản lý bình thường các phương tiện truyền thông





- ❑ Bề mặt tấn công là tổng thể tất cả các điểm tiếp xúc (entry points) hoặc vector tấn công (attack vectors) nơi kẻ tấn công có thể cố gắng truy cập trái phép vào hệ thống để trích xuất dữ liệu hoặc gây thiệt hại.
- ❑ Bề mặt tấn công càng nhỏ thì càng dễ bảo vệ.
- ❑ Các tổ chức phải:
 - Liên tục theo dõi bề mặt tấn công của mình để xác định và chặn các mối đe dọa tiềm ẩn càng nhanh càng tốt.
 - Cố gắng và giảm thiểu diện tích bề mặt tấn công để giảm nguy cơ thành công của các cuộc tấn công mạng.

- ❑ Vector tấn công là phương pháp mà tội phạm mạng sử dụng để truy cập trái phép hoặc xâm phạm tài khoản của người dùng hoặc hệ thống của tổ chức.
- ❑ Vector tấn công phổ biến:
 - Lừa đảo: Tin nhắn lừa đảo thường chứa liên kết hoặc tệp đính kèm độc hại khiến kẻ tấn công đánh cắp mật khẩu hoặc dữ liệu của người dùng.
 - Phần mềm độc hại: ví dụ như ransomware, Trojan và vi-rút. Nguy cơ phần mềm độc hại tăng lên khi bề mặt tấn công mở rộng.

□ Vector tấn công phổ biến:

- Mật khẩu bị xâm phạm: mọi người sử dụng mật khẩu yếu hoặc đã sử dụng lại trên tài khoản trực tuyến của họ.
- Sự cố mã hóa: triển khai mã hóa kém hoặc yếu có thể bị chặn để đọc tin nhắn gốc.
- Phần mềm chưa vá: Điều này giúp chúng có cơ hội xâm nhập vào mạng lưới và tài nguyên của tổ chức.

- ❑ Triển khai Chính sách Zero-trust: đảm bảo chỉ những người phù hợp mới có quyền truy cập đúng mức vào đúng tài nguyên vào đúng thời điểm.
- ❑ Loại bỏ sự phức tạp: Sự phức tạp không cần thiết có thể dẫn đến quản lý kém và sai lầm về chính sách, cho phép tội phạm mạng truy cập trái phép vào dữ liệu của công ty
- ❑ Quét lỗ hổng: xác định lỗ hổng và chỉ ra cách khai thác điểm cuối.
- ❑ Segment Network: cho phép các tổ chức giảm thiểu quy mô bề mặt tấn công của họ bằng cách thêm các rào cản ngăn chặn kẻ tấn công. Ex, Firewall
- ❑ Đào tạo nhân viên: Nhân viên là tuyến phòng thủ đầu tiên chống lại các cuộc tấn công mạng. Họ cần hiểu các biện pháp thực hành tốt nhất, phát hiện các dấu hiệu rõ ràng của một cuộc tấn công thông qua email lừa đảo và kỹ thuật xã hội.

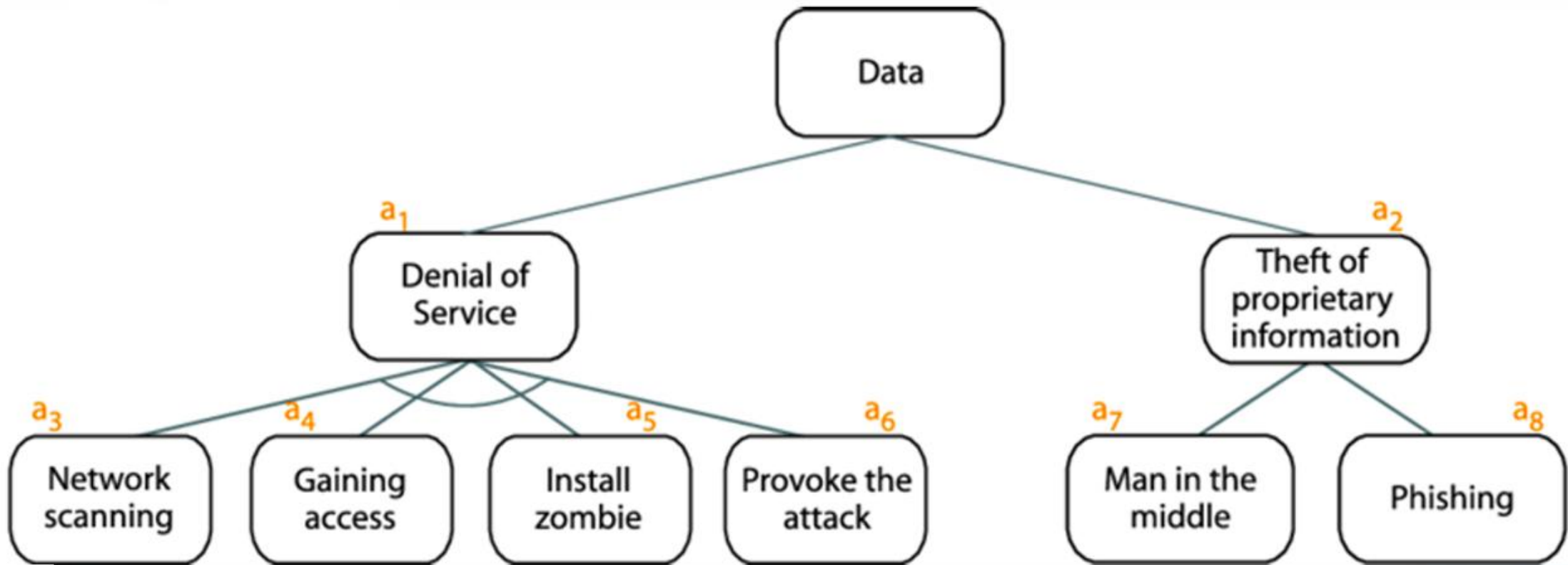
Cây tấn công:

- Là sơ đồ khái niệm cho thấy cách một tài sản hoặc mục tiêu có thể bị tấn công
- Đã được sử dụng để mô tả các mối đe dọa trên hệ thống máy tính và các cuộc tấn công có thể xảy ra để thực hiện các mối đe dọa đó

Bốn cách có thể sử dụng cây tấn công như một phần của thử nghiệm bảo mật ứng dụng:

- Khám phá các lỗ hổng đối với các cuộc tấn công nhiều bước trong mạng máy tính và thiết kế ứng dụng.
- Biểu diễn chi phí cho mỗi đường dẫn dọc theo cây.
- Cải thiện hiệu quả của chiến lược thử nghiệm của bạn.
- Đánh giá chi phí và hiệu quả của các biện pháp phòng thủ tiềm năng

Cây tấn công: ví dụ



☐ Kế hoạch bảo mật

- Prevention
- Detection
- Response
- Recovery and remediation

☐ Policy (what) vs. mechanism (how)

☐ Tính chính xác/đảm bảo: Nó có thực sự hiệu quả không?

- Đảm bảo: mức độ tin cậy
- Đánh giá: quá trình kiểm tra sản phẩm hoặc hệ thống máy tính theo các tiêu chí nhất định

1. Minimise attack surface area - Giảm thiểu vector tấn công vào hệ thống
2. Establish secure defaults - Thiết lập cơ chế mặc định an toàn
3. Least privilege - Đặc quyền tối thiểu
4. Defence in depth - Bảo mật theo chiều sâu, nhiều lớp
5. Fail securely - Xử lý thất bại một cách an toàn
6. Don't trust services - Không tin tưởng tuyệt đối vào dịch vụ
7. Separation of duties - Tách biệt về nhiệm vụ
8. Avoid security by obscurity - Tránh bảo mật bằng việc che giấu
9. Keep security simple - Giữ bảo mật một cách đơn giản
10. Fix security issues correctly - Vá lỗ hổng bảo mật một cách đúng đắn

- ☐ Định nghĩa về an toàn thông tin
- ☐ Các đặc điểm quan trọng của thông tin
- ☐ Mô hình toàn diện về an toàn thông tin
- ☐ Các phương pháp tiếp cận để triển khai an toàn thông tin
- ☐ Các giai đoạn của vòng đời phát triển hệ thống an ninh
- ☐ Các thuật ngữ chính của an toàn thông tin
- ☐ Các mối nguy hiểm của ATTT

Tiêu chuẩn CIA là gì?

- a. Confidentiality, Integrity, and Authentication**
- b. Confidentiality, Integrity, and Availability**
- c. Confidentiality, Integrity, and Accounting**
- d. Confidentiality, Integrity, and Access**

Tấn công chủ động có đặc điểm gì

- a. Khó phát hiện
- b. Dễ ngăn chặn
- c. Không gây nguy hiểm
- d. Làm thay đổi hệ thống

Chuẩn về an toàn thông tin là

- a. 27000**
- b. 28000**
- c. 20700**
- d. 25000**

Tấn công bị động có đặc điểm gì

- a. Dễ phát hiện
- b. Khó ngăn chặn
- c. Không làm thay đổi hệ thống
- d. Thực hiện nhanh

Độc trộm dữ liệu ảnh hưởng tiêu chuẩn gì?

- a. Confidentiality**
- b. Integrity**
- c. Availability**
- d. Accounting**

Tấn công Dos ảnh hưởng tiêu chuẩn gì?

- a. Confidentiality**
- b. Integrity**
- c. Availability**
- d. Accounting**

Tấn công giả mạo ảnh hưởng tiêu chuẩn gì?

- a. Confidentiality
- b. Integrity
- c. Availability
- d. Accounting

Từ khóa mô tả điểm yếu hay lỗi của hệ thống hoặc cơ chế bảo vệ để lộ thông tin

- a. vulnerability
- b. threat
- c. Attack
- d. Hacking

☐ Chọn một hệ thống thông tin

- Giả sử cần có một mô hình bảo mật để bảo vệ thông tin bằng cách sử dụng CIA Triad+.
- Thông tin trong lớp của bạn là gì Con người, phần cứng, phần mềm, quy trình, mạng, dữ liệu,....

☐ Cần bảo vệ dựa trên mô hình bảo mật CIA triad+

- Integrity
- Availability
- Confidentiality
- Authentication
- Accountability

Hãy xem xét thông tin được lưu trữ trên máy tính cá nhân của bạn. Đối với mỗi thuật ngữ được liệt kê, hãy tìm một ví dụ và ghi lại nó

- threat
- threat agent
- vulnerability
- exposure
- risk
- attack
- exploit

Sử dụng Web, tìm hiểu về các nhóm tấn công

☐ Họ là ai, ở đâu

☐ Họ đã làm gì

- Tấn công khai thác điểm yếu gì
- Tấn công hoạt động như thế nào

☐ Thiệt hại họ đã gây ra

- Mục tiêu của tấn công
- Mức độ Thiệt hại số lượng, số tiền

☐ Cách khắc phục

AN TOÀN THÔNG TIN (INSE330380)

Kết thúc chương 1

Ths. ĐỖ MINH HẬU



Trung tâm Học liệu và Dạy học số
Đại học Công nghệ Kỹ thuật Tp. Hồ Chí Minh
01 Võ Văn Ngân, P. Thủ Đức, Tp. Hồ Chí Minh
daotaotuxa@hcmute.edu.vn